PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

# Infrastructure de gestion de clés (IGC)

03-190 ANSSI - Infrastructure de gestion de clés IGC — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

**À RETENIR**

1. L'organisation hiérarchique comprend au minimum une AC racine et une AC intermédiaire par racine.
2. Les règles et pratiques de l'infrastructure sont définies par la PC et la DPC selon l'annexe A2 du RGS.
3. Le renouvellement d'un certificat impose le renouvellement systématique de la bi-clé.

## Conception de l'IGC

| Notion | À retenir |
|---|---|
| Hiérarchie AC | Au minimum **une AC racine** et **une AC intermédiaire** par racine. Chaque AC intermédiaire est dédiée à un ou plusieurs **gabarits** (métier/usage). |
| Politique/Gabarits | Définir **politique de certification** et **déclaration des pratiques** (annexe A2 du RGS). Limiter les extensions **X.509** (`Key Usage`, `Extended Key Usage`, `Authority Information Access`) aux besoins du gabarit. |
| Protection clés | Échanges protégés (**confidentialité, intégrité, authenticité**). AC racine : **hors ligne** (idéalement **HSM**). AC intermédiaire : **en ligne** (**HSM**). Entité finale : **contrôle d'accès** (+ chiffrement/matériel). |
| Cycle de vie | Bi-clés : source d'aléa et algorithmes du **Guide des mécanismes cryptographiques**. Révocation : **CRL** ou **OCSP** (deux mécanismes préférables). Bi-clé jamais réutilisée pour un autre usage ; clés de **chiffrement** séquestrées **hors ligne**. |
| Post-quantique | Anticiper la migration via l'**hybridation sur les certificats** et l'étude des impacts de performance, selon l'**Avis de l'ANSSI**. |

## Exploitation de l'IGC : points clés

| Notion | À retenir |
|---|---|
| Ressources humaines | Dédier des ressources à l'exploitation et au maintien. Vérifier la **légitimité** (conformité politique) et la **possession de la clé privée**. |
| Magasins et chaîne | Configurer uniquement les **AC strictement nécessaires**. Vérifier la **chaîne complète** (signature, statut de révocation, validité). |
| Renouvellement/Auto | Anticiper (ex: **2/3 de la durée de vie** pour l'AC racine). Automatiser via des protocoles comme `ACME`. Renouveler la **bi-clé** systématiquement. |
| Rôles et audit | Séparer **exploitation** et **administration** (ex: administrateur, opérateur). Journaliser et surveiller (émission, HSM, CRL, OCSP). Réaliser des **audits**. |

## Pièges et confusions

- ⚠ Confondre le stockage de l'AC racine (hors ligne) avec celui de l'AC intermédiaire (en ligne en HSM).
- ⚠ Croire qu'on peut simplement reconduire un certificat avec la même clé au lieu de renouveler la bi-clé.
- ⚠ Oublier que plus une clé est haute dans la hiérarchie, plus son exposition doit être réduite.
- ⚠ Négliger la combinaison de la CRL et de l'OCSP pour assurer une redondance de la révocation.

## Sigles et définitions

| | |
|---|---|
| **IGC** | Ensemble organisationnel et technique hiérarchique qui gère les certificats à usage interne à une entité. |
| **AC** | Entité qui émet des certificats, organisée en hiérarchie. |
| **PC** | Politique de certification définissant les règles d'une IGC. |
| **DPC** | Déclaration des pratiques de certification définissant les règles d'une IGC. |
| **HSM** | Équipement sécurisé matériel destiné à stocker les clés privées des autorités de certification. |
| **CRL** | Certificate Revocation List, mécanisme de gestion de la révocation des certificats. |
| **OCSP** | Online Certificate Status Protocol, mécanisme de gestion de la révocation des certificats. |
| **ACME** | Protocole permettant d'automatiser la génération, le déploiement et le renouvellement des certificats. |

## Auto-test

1. Quel est le nombre minimum d'AC intermédiaires par AC racine ?
2. Quel équipement matériel est destiné au stockage des clés privées des AC ?
3. À quel moment faut-il anticiper le renouvellement de l'AC racine ?
4. Quels sont les deux mécanismes de gestion de la révocation ?
5. Quel protocole permet d'automatiser le cycle de vie des certificats ?

Réponses : **1.** Une. · **2.** Un HSM. · **3.** Dès l'atteinte des 2/3 de la durée de vie. · **4.** La CRL et l'OCSP. · **5.** ACME.

---

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.